MSI+BIT Security of Software and Systems

Exercise sheet 02 - Security Engineering & Authentication

Discussion on Monday, November 17, 2025

Design Principles

Recall the design principles:

1. Secure by Design
2. Defense in Depth
3. Mission-Driven Security
4. Least Privilege
5. Isolation
6. Keep It Simple, Stupid (KISS)
7. Composability and Modularity
8. Fail-Safe Defaults
9. Reconfigurability & Autonomous Recovery
10. Auditability, Traceability & Logging
11. Rigorous Testing

Task 1

a) Pick 3 of the design principles and come up with an example (real-world or hypothetical) illustrating how it applies in practice.

b) Are there possible trade-offs or conflicts between these principles? Discuss them.

Task 2

You are part of a team designing a new multi-tenant cloud storage service for sensitive research data.

Tasks:

a) Identify three security design principles most critical for this system

b) For each, describe how it could be implemented concretely (e.g., through architecture, access control, or policy).

Task 3

A startup's web application recently suffered a data breach exposing user credentials.

Post-mortem reveals:

- Database credentials were stored in source code.
- Debug logging was left enabled in production.

- Developers used admin accounts for everyday operations.

Tasks:

a) Identify which security principles were violated and how.

b) Recommend specific corrective measures for each issue.

c) Identify which design principles could have prevented and which could have minimized the breach. Explain how.

Task 4

Design a secure IoT device system for smart home lighting.

Your design description (1–2 pages) should:

- Incorporate at least five of the listed security principles.
- Explain how each principle is implemented (e.g., firmware isolation, modular software updates, logging of control commands).
- Include a diagram to illustrate architecture or data flow.

Authentication

Task 5

A company wants to introduce a new ID card for its employees. The card will have a printed face image and an RFID chip, that can be used with a card reader and password to authenticate oneself online. Assume that the card is tamperproof and the protocols are secure and correctly implemented.

A) Which authentication factors could theoretically be used with this card? Name one attribute of the card for each factor that allows its usage.

B) Which authentication factors can be used in an online authentication? Assume that the client only has a computer, a keyboard and a simple card reader. Explain your answer.

C) Assume they additionally store a fingerprint on the card that should be used to realize access control at correspondingly secured doors. How would this change your answers to Task 5A) and Task 5B)?

Task 6

1. Which statements are correct?

A) Symmetric algorithms use the same key for encryption and decryption.
B) Asymmetric algorithms use different key pairs (public / private).
C) Symmetric algorithms are computationally more expensive than asymmetric ones.
D) Asymmetric algorithms are particularly suitable for large amounts of data.
E) Symmetric algorithms are usually faster in practice.

2. Which properties should a cryptographic hash function have?

A) Collision resistance
B) Pre-image resistance
C) One-Way
D) Reversibility
E) Constant output length

3. Which statements are correct?

A) A digital signature proves the authenticity and integrity of a message.
B) Digital signatures are usually based on asymmetric cryptography.
C) A digital certificate contains the private key of the owner.
D) Certificates are signed by certification authorities (CAs).
E) Certificates are used for secure key distribution.

4.Assign each cryptographic technique to its typical use case. Which combinations are correct?

A) Password storing – Hash function with salt
B) Digital signatures – Proof of integrity and authenticity
C) Asymmetric encryption – Secure exchange of secret keys or messages
D) Symmetric encryption – Efficient protection of large amounts of data

Task 7

A system uses the following procedure to store user passwords. The passwords are 9-bit numbers. Let p be a user password. The system stores $H(p) = p^2 \bmod 256$.

An attacker extracted the following values from the database: $h_1 = 144$, $h_2 = 113$, $h_3 = 161$.

A) Find possible passwords that would create those values.

B) Discuss why trivial passwords (like small numbers) can easily be recovered by attackers.

C) Dicsuss mathematically why the chosen function $H(p)$ is insecure.

D) Propose practical improvements for the used procedure.

Task 8

A web application "PhotoCreative" wants to take advantage of the fact that many users already have an account with "YourCloud", where their photos are stored.
The developers of PhotoCreative want to avoid storing user photos themselves and instead access them through the user's existing YourCloud account.

A) Is this a use case for OAuth or OpenID Connect (OIDC)?
Explain your answer.
B) Draw the Authorization Code Flow for the interaction between PhotoCreative and YourCloud.
Highlight the exchange of tokens in your diagram.
C) Assume an attacker can eavesdrop on the HTTP traffic between the user and YourCloud (i.e., HTTPS is not used). What could the attacker achieve in this situation?
D) Discuss the difference between an Access Token and an ID Token in OIDC.
Provide an example of when each one is used.
E) Assume PhotoCreative wants to enforce multi-factor authentication (MFA) at YourCloud.
How would this change the flow? What are the security benefits of this modification?